

K-Waay 批处理接纳中参与方区分条件的形式化分析

匿名作者

摘要

K-Waay 完整规范已要求一次 `BatchReceive` 调用中的输入分别对应不同参与方。为明确这一不同参与方条件 (different-party condition) 所维护的批内关系, 并检验消息或发送发生坐标上的限制能否替代该关系, 构造共享同一发送来源与顺序处理生命周期的固定两槽 Tamarin 模型, 受控比较放宽配置、消息级配置和参与方级正控制 (positive control)。验证结果表明: 放宽配置允许一个精确发送来源在同一批次上下文中对应两个接收事件; 消息级配置能够满足消息区分和作用域内发生注入性, 但同一参与方产生的不同消息仍可共同获接纳; 参与方级配置维持批内参与方区分, 且有效的不同参与方批次可达。结果说明, 消息区分和精确来源上的发生注入性不能替代参与方级关系。该结论限于固定两槽的批处理接纳抽象, 不扩张为完整 K-Waay 协议的攻击或任意批长定理。

关键词: K-Waay; 批处理接纳; 不同参与方条件; Tamarin; 形式化验证

Abstract

The complete K-Waay specification already requires the inputs of one `BatchReceive` invocation to correspond to different parties. To clarify the same-batch relation maintained by this condition and to test whether controls over message or sender-occurrence coordinates can replace it, we construct three fixed-two-slot Tamarin models with a common sender-origin and sequential processing lifecycle. The controlled comparison covers relaxed admission, a message-level restriction, and a party-level positive control. The relaxed configuration admits a trace in which one exact sender origin supports two receiver events in the same batch context. The message-level configuration satisfies message distinction and scoped occurrence injectivity, while two different messages from one party can still be accepted together. The party-level configuration preserves same-batch party distinction and retains a reachable valid distinct-party batch. Hence, message distinction and exact-origin occurrence injectivity do not substitute for the required party relation. The conclusion is limited to the fixed-two-slot admission abstraction and does not constitute an attack on complete K-Waay executions or a theorem for arbitrary batch sizes.

Key words: K-Waay; batch admission; distinct-party condition; Tamarin; formal verification

0 引言

后量子安全消息协议通常以单次握手、单条消息或单个会话为分析对象, 但异步接收接口还可能把多个发送方关联输入纳入一次处理。此时, 单个条目的来源与安全性质只能说明该条目自身满足什么条件, 不能自动确定多个条目共同出现时应保持何种关系。已有安全消息研究也表明, 组合边界可能承载独立于组件性质的安全义务 [1]; 批处理接纳正是这类需要单独刻画的边界。

K-Waay 是一种后量子、类似 X3DH 的可否认认证密钥交换协议 [2]。其 `BatchReceive` 操作在共享接收方状态下处理多个发送方关联输入, 完整规范已明确要求同一次调用中的元素对应不同参与方 [3, Sec. 5.1, p. 21]。因此, 问题并非协议是否遗漏了参与方检查, 而是这一既有条件在批次内部维护了什么关系, 以及单个条目具有正确来源时, 批内参与方关系能否随之成立。

围绕安全消息协议, Signal 和 PQXDH 等工作的形式化分析主要处理握手、会话及密钥安全性质 [4, 5]; Tamarin 则为安全协议的符号迹建模和性质验证提供了通用方法 [6]。身份名称、认证注入性和会话组合研究进一步说明, 参与方表示、事件对应及组合层性质需要分别界定 [7, 8, 1]。这些工作提供了分析工具和概念基础, 但尚未直接回答 BatchReceive 的一个具体问题: 同一批次中的消息、发送发生和参与方坐标之间能否相互替代。

据此, 本文不把“K-Waay 是否存在漏洞”作为研究设问, 而是考察原协议不同参与方条件约束的身份坐标。若同一参与方可以通过不同发送发生产生不同消息, 那么消息不等、精确来源不重复与参与方不重复就是三种不同陈述。需要验证的是: 消息级或发送发生级限制成立时, 是否仍可能在一个获接纳批次中重复参与方。

分析固定两个槽位, 在相同的发送、网络暴露、条目收集、来源匹配和顺序处理骨架上, 仅改变接纳条件。放宽配置用于观察参与方条件移除后的行为, 消息级配置检验替代关系, 参与方级配置作为正控制直接约束目标坐标。Tamarin 验证显示, 放宽配置可由一个精确发送来源产生同一批次中的两个接收事件; 消息级配置同时满足消息区分和作用域内发生注入性, 却仍允许同一参与方的不同消息共同获接纳; 参与方级配置则维持参与方区分, 并保留可达的有效批次。

主要贡献包括:

- 1) 形式化刻画 BatchReceive 既有不同参与方条件对应的批内参与方关系, 并区分参与方、消息和发送发生三个坐标;
- 2) 在共同两槽生命周期上构造受控接纳配置, 检验其他身份坐标上的限制能否替代目标关系;
- 3) 通过机器结果给出坐标分离证据: 消息区分与作用域内发生注入性可以同时成立, 但不能推出批内参与方区分; 参与方级正控制同时保持目标性质和有效批次可达性。

1 K-Waay 批处理接纳与参与方区分问题

1.1 BatchReceive 机制与不同参与方条件

K-Waay 由 KEM、数字签名和 split-KEM 等密码组件构成, 其完整握手和计算安全证明超出当前问题所需范围 [2]。这里保留的协议对象是接收侧批处理接口: 发送方调用 Send 产生协议消息; 当多条发送方消息对应同一接收方临时状态时, 接收方以该共享状态调用 BatchReceive [3, Sec. 4.1]。其输入可概括为未编号向量

$$S = ((pk_{j_1}, prek_{j_1}, m_{j_1}), \dots, (pk_{j_d}, prek_{j_d}, m_{j_d})), \quad d \geq 1,$$

其中每个分量包含所声称发送方的公钥、预密钥束和协议消息。该表示仅用于说明一次接收操作能够组合多个发送方关联输入, 不展开各分量的解封装和密钥派生过程。

完整规范在 BatchReceive 的描述中要求, 同一次调用的各元素对应不同参与方 [3, Sec. 5.1, p. 21]。该条件约束的是一个批次内部的元素关系, 而非参与方在全部协议执行中的全局唯一性, 也不限制某一参与方只能产生一条消息。规范给出关系本身, 但没有在这段条件中指定由调用者、批次构造器还是接纳层维护它。

因此, 后续分析只关注候选条目被组合并作为一个批次接纳时的参与方关系。这里的“批处理接纳”是描述分析边界的术语, 不是对原协议增加新的算法; 需要形式化的对象也不是完整密码流程, 而是同一 BatchReceive 调用中各条目的身份投影。

1.2 身份坐标与问题实例

将批处理接纳所需的条目信息抽象为

$$E_i = (A_i, oid_i, m_i), \quad (1)$$

其中, A_i 表示建模参与方, oid_i 表示一次发送发生, m_i 表示相应消息。中文稿中的 oid 对应 Tamarin 源模型中的 sid , 但不表示 K-Waay 完整协议中的 transcript 或 session 标识。式(1)是分析记号, 不是协议输入的线路编码。

表 1 身份坐标与模型映射

概念	论文记号	Tamarin 记号	作用	解释边界
参与方	A	A	标识建模协议主体	不自动等同于账户或密钥编码
发送发生	oid	sid	区分发送方产生条目的发生	发生不同不推出参与方不同
消息	m	m	表示发送方产生的符号消息	消息不同不推出参与方不同
槽位	i	线性收集状态	标识批次内位置	位置不同不保证条目内容互异
批次/接收上下文	(bid, rst)	(bid, rst)	限定共同处理作用域	不表示完整接收方状态

这些坐标回答不同问题: 槽位和 (bid, rst) 确定条目所处的批次上下文, m 区分消息内容, oid 区分发送发生, A 则给出不同参与方条件所作用的投影。 A 是符号模型中的协议主体, 不自动等同于账户、公钥字节串或数据库记录; 具体系统若要比对参与方表示, 还需另行说明从实现对象到该坐标的映射。

考虑两个候选条目 (A, oid_1, m_1) 和 (A, oid_2, m_2) , 其中 $oid_1 \neq oid_2$ 且 $m_1 \neq m_2$ 。二者来自不同发送发生并携带不同消息, 但参与方投影仍同为 A 。这一最小实例说明, 消息不同和发送发生不同都不足以推出参与方不同; 需要检验的是获接纳批次中的参与方投影, 而非其他坐标是否互异。

1.3 研究问题

上述区分形成三个研究问题:

RQ1: 放宽不同参与方条件后, 固定两槽接纳抽象中哪些重复参与方组合可达?

RQ2: 一个精确发送来源能否在同一批次和接收方上下文中支持两个 ReceiverAccept 事件?

RQ3: 消息级限制能否替代参与方级条件, 还是同一参与方的不同消息仍可同时获接纳?

为排除处理流程差异的影响, 后续模型在相同两槽生命周期上保持发送、收集、来源匹配和顺序处理不变, 只调整接纳条件所约束的坐标。

2 批处理接纳的形式化建模

2.1 安全目标与攻击者模型

设 $B = (E_1, \dots, E_n)$ 为有序批次, $\text{party}(E_i)$ 表示条目 E_i 的参与方投影。不同参与方条件对应的批内目标定义为

$$\text{DistinctPartyPerBatch}(B) \triangleq \forall 1 \leq i < j \leq n, \quad \text{party}(E_i) \neq \text{party}(E_j). \quad (2)$$

该关系要求一个批次中任意两个不同位置都投影到不同参与方, 但不要求参与方、消息或发送发生活跃于其他批次时仍保持全局唯一。定义面向任意有限批次给出, 机器分析取最小的非平凡情形 $n = 2$, 此时目标化为 $A_1 \neq A_2$ 。

攻击者采用标准 Dolev-Yao 符号网络能力，并在候选条目已经暴露后控制两槽批次的组合：可以保留、重放、选择和排列已有条目，既可重复同一精确元组，也可选取同一参与方产生的两个不同合法元组。该能力只改变候选条目的组合方式，不赋予攻击者生成诚实参与方内部状态或制造合法来源的能力。接收事件的来源按完整 (A, oid, m) 元组匹配；仅有参与方 A 相同，不能凭空得到相应的 Send 来源事实。

机器模型固定两个槽位，批次组合控制是形式分析中的能力假设，直接机器证据止于 ReceiverAccept 事件。目标和攻击者能力因而都位于候选条目形成之后、分量被接收处理之前的批处理接纳边界。

2.2 Tamarin 模型与共同生命周期

Tamarin 以多集重写规则描述状态变化，并用动作事实记录可供迹性质引用的事件 [6]。发送规则为参与方产生新鲜的发送坐标和消息，发出 $\text{Send}(A, oid, m)$ 动作，将 (A, oid, m) 暴露到符号网络，同时保存持久事实 $!Sent(A, oid, m)$ 。前者记录发送事件，后者表示模型中的精确来源关系；该持久事实是抽象假设，不是对真实协议认证机制的直接实现。

网络上的候选元组随后进入两个线性槽位。第一个收集状态保存 E_1 并开放第二个槽位，第二个状态保存 E_2 ，二者共享批次标识 bid 和接收方上下文 rst 。这里的 rst 仅标识模型中的共同接收上下文，不展开 K-Waay 接收方临时状态的密码结构。

收集完成后，接纳规则根据所选配置决定进入拒绝状态或顺序处理状态。获接纳路径先记录 BatchReceive 动作，再依次处理槽位 1 和槽位 2。每个处理步骤都必须匹配相应的 $!Sent(A, oid, m)$ ，随后记录携带 (A, oid, m, bid, rst) 的 ReceiverAccept 动作。持久来源事实可以在精确元组被重复收集时支持多个处理步骤，这正是后续注入性性质需要检查的情形。

三种配置完全共享发送生成、网络暴露、两槽收集、精确来源匹配、顺序处理及 ReceiverAccept 事件。分析变量仅是收集完成后的接纳坐标及其对应拒绝分支，因此后续性质差异可归因于接纳条件，而不是生命周期变化。

2.3 接纳配置与验证性质

表2给出三种受控配置。放宽配置不增加坐标限制，用于观察条件移除后的基线行为；消息级配置只比较消息坐标，用于检验其能否替代参与方关系；参与方级配置直接比较目标坐标，作为正控制验证目标性质及其非真空性。三者都是同一抽象上的实验条件，不构成三套新协议或修复方案。

表 2 接纳配置与验证目标

配置	约束坐标	接纳条件	分析角色	主要性质
放宽配置	无	无不等式约束	条件移除基线	精确来源重复；发生注入性
消息级配置	消息 m	$m_1 \neq m_2$	坐标替代对照	消息区分；发生注入性；同一参与方见证
参与方级配置	参与方 A	$A_1 \neq A_2$	目标关系正控制	参与方区分；有效批次可达性

除代表性路径的可达性外，模型还检查精确来源对应、作用域内发生注入性、消息区分和参与方区分。为避免由名称推断性质含义，下面的不编号语义表按 Tamarin 中的真实量词范围给出四类性质。

性质	迹语义	解释边界
精确来源对应	$\text{ReceiverAccept}(A, oid, m, bid, rst)@r$ 推出存在 $s < r$ 使 $\text{Send}(A, oid, m)@s$ 成立	匹配完整 (A, oid, m) ，不是仅匹配参与方 A
作用域内发生注入性	同一 $\text{Send}(A, oid, m)@s$ 早于两个坐标均为 (A, oid, m, bid, rst) 的接收事件时，推出 $r_1 = r_2$	检查一个精确来源是否对应多个不同接收事件，不检查参与方数目
消息区分	同一 (bid, rst) 中若 $r_1 \neq r_2$ ，则消息级配置要求 $m_1 \neq m_2$	不主张消息跨批次或跨执行全局唯一
参与方区分	同一 (bid, rst) 中若 $r_1 \neq r_2$ ，则参与方级配置要求 $A_1 \neq A_2$	结论只作用于接收事件的参与方投影

其中，作用域内发生注入性的精确前件可写为未编号式

$$\begin{aligned}
 \forall A, oid, m, bid, rst, s, r_1, r_2 : \quad & \text{Send}(A, oid, m)@s \\
 & \wedge \text{ReceiverAccept}(A, oid, m, bid, rst)@r_1 \\
 & \wedge \text{ReceiverAccept}(A, oid, m, bid, rst)@r_2 \\
 & \wedge s < r_1 \wedge s < r_2 \implies r_1 = r_2.
 \end{aligned}$$

该性质把一个精确发送来源与同一批次、同一接收方上下文中的接收事件数联系起来；它不比较两个不同来源的参与方投影，也不直接回答一个批次中包含多少个不同参与方。消息区分和参与方区分则分别约束不同接收事件的消息坐标和参与方坐标，三者不能按名称视为递进或等价关系。

参考文献

- [1] Cas Cremers, Charlie Jacomme, and Aurora Naska. Formal analysis of session-handling in secure messaging: Lifting security from sessions to conversations. In *32nd USENIX Security Symposium*, pages 1235–1252, 2023.
- [2] Daniel Collins, Loïs Huguenin-Dumittan, Ngoc Khanh Nguyen, Nicolas Rolin, and Serge Vaudenay. K-Waay: Fast and deniable post-quantum X3DH without ring signatures. In *33rd USENIX Security Symposium*, pages 433–450, 2024.
- [3] Daniel Collins, Loïs Huguenin-Dumittan, Ngoc Khanh Nguyen, Nicolas Rolin, and Serge Vaudenay. K-Waay: Fast and deniable post-quantum X3DH without ring signatures. Cryptology ePrint Archive, Paper 2024/120, 2024. Full version of the USENIX Security 2024 paper. <https://eprint.iacr.org/2024/120>.
- [4] Katriel Cohn-Gordon, Cas Cremers, Benjamin Dowling, Luke Garratt, and Douglas Stebila. A formal security analysis of the Signal messaging protocol. *Journal of Cryptology*, 33:1914–1983, 2020.
- [5] Karthikeyan Bhargavan, Charlie Jacomme, Franziskus Kiefer, and Rolfe Schmidt. Formal verification of the PQXDH post-quantum key agreement protocol for end-to-end secure messaging. In *33rd USENIX Security Symposium*, pages 469–486, 2024.
- [6] Simon Meier, Benedikt Schmidt, Cas Cremers, and David Basin. The TAMARIN prover for the symbolic analysis of security protocols. In *CAV 2013; LNCS 8044*, pages 696–701, 2013.
- [7] Simone Lupetti, Feike W. Dillema, and Tage Stabell-Kulø. Names in cryptographic protocols. In *4th International Workshop on Security in Information Systems (WOSIS 2006)*, pages 185–194, 2006.
- [8] Gavin Lowe. A hierarchy of authentication specifications. In *10th IEEE Computer Security Foundations Workshop*, pages 31–43, 1997.